



07.09.2025

ON-PREM TOOL FOR AGENTIC RED TEAMING

Комплексно проверяем безопасность AI-агентов — внутри контура и до выхода в прод

Для команд AI Security и MLSecOps: MOROK атакует память и инструменты агента, подтверждает находки состоянием системы и сохраняет их для повторной проверки.

Проблема: ручной аудит не успевает за потоком изменений, а проверка «запрос → ответ» не видит, что агент сделал с данными и инструментами.

**МО́РОК наведём —
уязвимости найдём.**

Одна команда сможет проверять весь поток агентов — без расширения штата

ПРОВЕРОК В ГОД

×5

300 → 1 500

Та же команда из трёх специалистов закрывает умеренный входящий поток.

МОДЕЛЬ · 4 Ч/АГЕНТ

СЕБЕСТОИМОСТЬ ТЕХПРОВЕРКИ

−80%

36–66 → 5–13 тыс. ₽

Машина ведёт кампанию; эксперт подключается к профилю и подтверждённым находкам.

МОДЕЛЬ · 2–4 Ч/АГЕНТ

ПОВТОР ПОСЛЕ РЕЛИЗА

до ×30

недели → минуты

Найденная атака становится тестом и переигрывается после изменения модели, промпта или прав.

ОЦЕНКА ПОРЯДКА

БАЗА

Факты из интервью: 3 специалиста, до 5 агентов в день на человека, 2–3 дня ручной проверки. **Допущение MOROK:** 2–4 человеко-часа на агента; валидируем на пилоте.

ПОЧЕМУ СЕЙЧАС

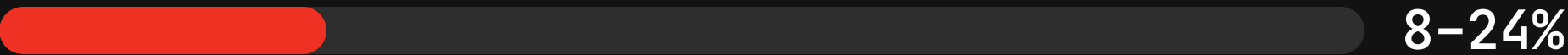
Ручная команда успевает проверить лишь 8–24% входящего потока

03

СПРОС ПО ИНТЕРВЬЮ

1 250–3 750

проверок в год — умеренный и пиковый сценарии



ТЕКУЩАЯ ЁМКОСТЬ

300 проверок в год

ЗАКРЫТЬ НАЙМОМ

+10–35

специалистов

45–190 млн ₽ полной годовой стоимости

ЗАКРЫТЬ ЗАКУПКОЙ

400–800 тыс. ₽

за один проект

и 2–6 недель на аудит одного агента

LIVE DEMO • ОДИН АУДИТ ЦЕЛИКОМ

От архитектуры агента — до доказанной находки и повторного теста

АРТЕФАКТЫ ЦЕЛИ



ПРОФИЛЬ



КАМПАНИЯ АТАК



EVIDENCE



ОТЧЁТ + RETEST

Не экскурсия по вкладкам — путь специалиста к решению о риске.

ПЕРЕХОДИМ В ПРОДУКТ →

Новую цель подключаем профилем — ядро MOROK остаётся неизменным

ВХОД

Архитектура,
API, роли,
инструменты,
память

White-box:
документация и
доступ к
авторизованному
тестовому контуру.

01 · ПРОФИЛЬ ЦЕЛИ

Единственное место target-специфики: роли, endpoints, доступные evidence-источники и правила reset.

02 · ГРАНИЦА ЦЕЛИ

Adapter + evidence providers

Один интерфейс для действий и наблюдений: tool calls, память, callbacks, audit log.

03 · ЯДРО MOROK

Нормализация → assertions → verdict → runner

LLM предлагает атаки. Код решает, доказан ли эффект.

ПОЧЕМУ ТАК

Переносимость

Новый агент — новый профиль и адаптер, а не новая система аудита.

ПРИНЦИП

Факт важнее
ответа модели

Нет наблюдаемого состояния — нет статуса «атака доказана».

ВЫХОД

Finding → отчёт
→ regression

Находка сохраняется и переигрывается после следующего релиза.

Продуктовый контур собран; экономику подтверждаем на пилоте

СДЕЛАНО

Полный workflow

Профиль → surface map → генерация → кампания → evidence → два отчёта → replay.

ПРОВЕРЕНО

4 / 4 ВАС

ASR 100% на одном намеренно уязвимом учебном стенде и одном классе атак.

ИНЖЕНЕРНАЯ БАЗА

493 теста · ОК

Последний подтверждённый snapshot проекта от 05.09.2026.

НАБЛЮДАЕМОСТЬ

19 spans

Живой W3C trace от запуска кампании до вызова инструмента.

НА ПИЛОТЕ ИЗМЕРЯЕМ

Время аудита от профиля до evidence-отчёта

Релевантность и false positives

Принятие finding командой агента

Стоимость retest после релиза

ВКЛАД КОМАНДЫ

Иван — продукт · Даниил — ядро и кампании · Тамерлан — evidence, regression и отчётность

СЛЕДУЮЩИЙ ШАГ • 4 НЕДЕЛИ

Нужен design partner с реальным агентом и авторизованным контуром

Цель пилота — заменить расчётную модель
измеренным временем аудита, качеством evidence и
стоимостью повторной проверки.

СДЕЛАНО

Рабочий end-to-end workflow

ПРОВЕРЕНО

State evidence и
воспроизводимый запуск

ДАЛЬШЕ

Первый evidence-отчёт
на реальном агенте

ФИНАЛЬНАЯ ФРАЗА • 10-15 СЕКУНД

MOROK превращает разовый ручной аудит в повторяемый on-prem процесс: больше проверенных агентов, ниже себестоимость, быстрый retest. Рабочий контур уже собран; следующий шаг — четырёхнедельный пилот с design partner.

Agentic-система — это не чат: риск живёт в памяти, правах и действиях

A1

ГДЕ ИСПОЛЬЗУЮТ

Критичные процессы

Поддержка клиентов, платежи и операции, продажи, HR и бэк-офис.

ОШИБКА = ДЕНЬГИ И РЕПУТАЦИЯ

ЧТО АТАКУЮТ

Автономную систему

Агент планирует шаги, читает данные, пишет в память и вызывает инструменты без человека.

ПАМЯТЬ TOOLS РОЛИ ИНТЕГРАЦИИ

ПОЧЕМУ СТАРЫЙ ПОДХОД СЛАБ

«Запрос → ответ» ВИДИТ ТОЛЬКО ТЕКСТ

Компрометация может проявиться позже: в другой сессии, у другого пользователя или в фактическом tool call.

НУЖНО НАБЛЮДАЕМОЕ СОСТОЯНИЕ

Три интервью сузили первый сегмент до команд с высоким риском и закрытым контуром

A2

3 CUSTDEV

Альфа-Банк · AI Security
Lab ИТМО · Raft

Сигналы: аудит выбивает из SLA; важны MCR/BAC и трейсы; 2–3 дня на техпроверку; finding должен быть доказуемым; эксперт остаётся в контуре решения.

Качественный discovery, не количественное подтверждение рынка.

ВЫБРАН

Банки и организации
с повышенными
требованиями к ИБ

On-prem инструмент во внутренней инфраструктуре.

ПОКУПАТЕЛЬ

CISO / ДКБ / риск-функция — владелец риска и бюджета.

ПОЛЬЗОВАТЕЛЬ

AI Security / MLSecOps — запускает кампанию и делает triage.

ПОТРЕБИТЕЛЬ

Команда агента и риск-комитет — исправляют и принимают решение о релизе.

Свободная ниша – on-prem red teaming полного agentic-контура с state evidence

A3

КРИТЕРИЙ	MOROK	Prompt / LLM scanners	Аудит как услуга	Foreign agentic SaaS
On-prem	●	◐	●	○ / custom
Memory + cross-session	●	○ / не раскрыто	вручную	◐–●
Tool arguments + state	●	○ / ◐	вручную	●
Replay / regression	●	◐	○ / retest	◐–●
Формат	workflow для эксперта	сканер	проект	платформа

Сценарии связывают стандарт, поверхность цели, доказательство и retest

A4

КАТАЛОГ

Память: policy-conformant poisoning

ASI06 · memory write · cross-user

Память: cross-session effect

inject → persist → activate

Память → чужой tool call

ASI06 → ASI03 · principal mismatch

Обход доступа через tool arguments

ВАС · фактический аргумент вызова

Разведка системного промпта

текстовый сигнал · потолок indirect

01

Композиция

шаблон × профиль цели



02

Генерация payload

варианты доставки и многошаговые цепочки



03

Прогон + traces

ответы, tool calls, память, snapshots



04

State evidence

детерминированный verdict



05

Regression

та же атака после исправления

Три владельца закрыли продукт, campaign engine и evidence lifecycle

A5

ПРОДУКТ

Иван

Discovery, сегменты, ценность, UX и защита продукта.

ИНЖЕНЕРИЯ

Даниил

Ядро атак, оркестрация кампаний, генерация и интеграция с целью.

ИНЖЕНЕРИЯ

Тамерлан

State oracle, evidence, traces, regression и отчётность.

КАК ПРОЕКТИРУЕМ

Spec-driven development

Сначала сценарий, доказательство и границы — потом код. Каждая задача имеет владельца и критерий готовности.

Факт важнее мнения модели

LLM расширяет поиск атак; код подтверждает результат; человек интерпретирует риск.

ЧТО СДЕЛАЛА КОМАНДА

Единый campaign runner для CLI и UI

Профильная архитектура без target-specific кода в ядре

Evidence и lifecycle от finding до closed/reopened

Два отчёта — технический и бизнесовый

Даже пессимистичный сценарий увеличивает ёмкость команды в 2,5 раза

A6

СЦЕНАРИЙ	ЧАСОВ / АГЕНТ	ПРОВЕРOK / ГОД	РОСТ ЁМКОСТИ	СЕБЕСТОИМОСТЬ
AS-IS	20 ч	300	—	36–66 тыс. ₺
Пессимистично	8 ч	750	×2,5	18–22 тыс. ₺
База	4 ч	1 500	×5	9–11 тыс. ₺
Оптимистично	2 ч	3 000	×10	5–6 тыс. ₺

Допущение: 250 рабочих дней; 3 специалиста; 18–22 тыс. ₺/человеко-день.

все T0-BE значения измеряем в пилоте

Шесть вопросов, на которые отвечаем за 30 секунд

A7

ПОЧЕМУ НЕ ГОТОВОЕ РЕШЕНИЕ?

Prompt-scanners не видят полный lifecycle памяти и tool arguments; зарубежный SaaS не подходит закрытому контуру; услуга плохо повторяется после каждого релиза.

СКОЛЬКО СТОИТ?

Цену MOROK не называем до пилота. Сначала измеряем compute, поддержку профиля и время triage. 400–800 тыс. ₽ — якорь ручной альтернативы, не наш прайс.

ЧТО С ДАННЫМИ?

On-prem: документация, traces и отчёты остаются внутри компании. Активные атаки идут только на авторизованный подготовленный контур с синтетическими данными.

КТО ПОДДЕРЖИВАЕТ?

MOROK поддерживает ядро и каталог; команда заказчика владеет профилем цели и принимает решение по риску. Новый класс цели может потребовать адаптер.

ЧТО ЕСЛИ МЕТРИКА УПАДЁТ?

ASR не оцениваем отдельно: смотрим покрытие, разнообразие, ошибки и штатный сценарий. Падение может означать исправление, деградацию генератора или потерю evidence — причины разделены.

КТО ЗА ЧТО ОТВЕЧАЕТ?

Иван — продукт и экономика. **Даниил** — campaign engine и интеграция. **Тамерлан** — evidence, regression и отчёт.